Executive summary

Introduction

- This report investigates a cyberattack on LionHealth's network, compromising confidentiality and causing network slowdowns. It details the attack specifics, threats involved, and mitigation strategies.

Project Problem and Scope

- On September 11, 2015, LionHealth experienced a 4 minute and 44 second, high severity cyberattacks involving trojan malware, ransomware, and outdated software vulnerabilities, exposing sensitive information.

High-Level Description

The attack:

- Targeted Franklion-PC running Windows.
- Used malicious scripts (Trojan/JS. Iframe. p, JS. Redirector. a) and CryptoWall ransomware.
- Exploited an outdated Flash version and leveraged attacker IPs for Command-and-Control operations.

Indicators of Compromise

- Unauthorized traffic from attacker IPs:
  - 104.28. 9. 93
  - 216. 245. 212. 78
  - 188. 165. 164. 184
  - 192. 186. 222. 229
  - 69. 49. 96. 13
- Evidence of Command-and-Control (C2) server communications.

Vulnerabilities

- Outdated software.
- Malware (Trojan)

Key Learnings

- Outdated software and unsecured browser extensions are critical vulnerabilities.

Conclusion

- The attack revealed gaps in LionHealth’s network defences, highlighting the need for updated systems, initiative-taking monitoring, and enhanced security measures.

Recommendations

- Remove malware, isolate infected systems, and restore from clean backups.
- Regularly update software and deploy anti-malware tools.
- Use up-to-date and secure applications.

Table of Contents

Introduction: 3

Network Diagram: 3

Details about the incident: 3

Details about the victim: 4

Details about the attackers: 4

Indicators of compromise: 4

Malware information (Name, hash and exe): 5

- **Trojan/JS.Iframe.p:** 5
- **Trojan/JS.Redirector.a:** 6
- **CryptoWall** 7

Vulnerabilities identified: 8

Threats/Vulnerabilities identified and methods to mitigate them: 8

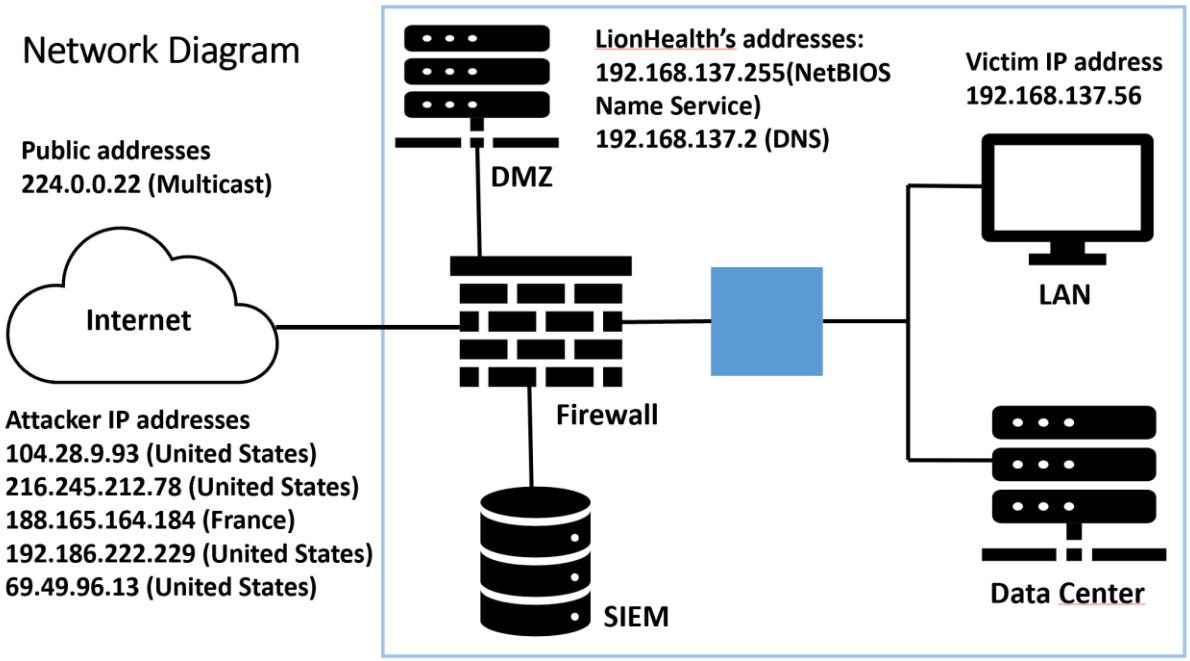
- **Mitigating Trojan/JS.Iframe.p:** 8
- **Mitigating Trojan/JS.Redirector.a:** 9
- **Mitigating CryptoWall:** 10
- **Mitigating Outdated flash version M1:** 11

Description of the event: 11

Introduction:

I am Matthew, a first-level Security Operations Centre (SOC) analyst at LionHealth. One day, I received complaints from users that network traffic is slow. After looking deeper into the situation, I suspect that there are cyber-attacks on my company's network and systems. This report will contain information about the cyberattack and methods to mitigate it.

Network Diagram:



Details about the incident:

- **Date: 11 September 2015**
- **Time: 19: 49: 11**
- **Duration: 4 minutes 44 seconds**
- **Impact (CIA): Confidentiality**
- **Severity: High**
- **Summary: The cyberattack happened on 11 September 2015 at 19: 49: 11. The attack lasted 4 minutes 44 seconds. This attack has a high severity compromising the confidentiality of LionHealth's network and systems.**

Details about the victim:

- **IP address: 192. 168. 137. 56**
- **MAC address: 14-FE-B5-AB-EC-7D**
- **Hostname: Franklion-PC**
- **Operating System: Windows XP/2000**

Details about the attackers:

IP addresses:

- 104. 28. 9. 93
- 216. 245. 212. 78
- 188. 165. 164. 184
- 192. 186. 222. 229
- 69. 49. 96. 13

Indicators of compromise:

RT	18	seconion-...	5.1652	2015-09-11 19:49:11	104.28.9.93	80	192.168.137.56	49181	6	ET CURRENT_EVENTS Pos...
RT	2	seconion-...	5.1670	2015-09-11 19:49:19	192.168.137.56	49222	216.245.212.78	80	6	ET POLICY Outdated Flash ...
RT	26	seconion-...	5.1671	2015-09-11 19:49:28	216.245.212.78	80	192.168.137.56	49315	6	ET DELETED Angler EK XT...
RT	12	seconion-...	5.1675	2015-09-11 19:49:28	216.245.212.78	80	192.168.137.56	49315	6	ET DELETED Angler EK XT...
RT	13	seconion-...	5.1687	2015-09-11 19:49:28	216.245.212.78	80	192.168.137.56	49315	6	ET DELETED Angler EK XT...
RT	2	seconion-...	5.1722	2015-09-11 19:49:32	192.168.137.56	49318	188.165.164.184	80	6	ET POLICY Possible IP Che...
RT	30	seconion-...	5.1723	2015-09-11 19:49:33	192.168.137.56	49319	192.186.222.229	80	6	ET TROJAN CryptoWall Che...
RT	2	seconion-...	5.1734	2015-09-11 19:53:55	69.49.96.13	80	192.168.137.56	49489	6	ET CURRENT_EVENTS Evil...
RT	2	seconion-...	5.1735	2015-09-11 19:53:55	69.49.96.13	80	192.168.137.56	49489	6	ET CURRENT_EVENTS Evil...

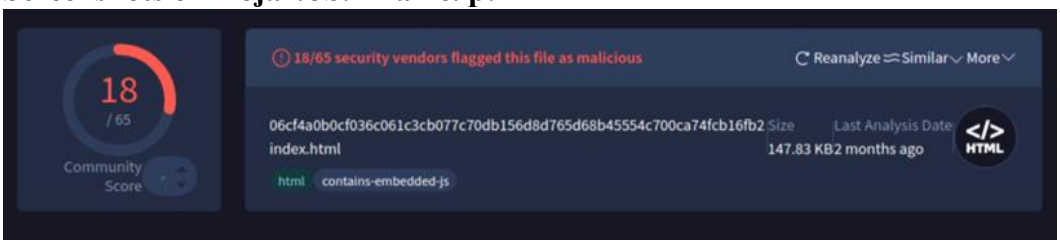
Summary: On 11 September 2015, 19: 49: 11 the attack started with nine logs lasting until 19: 53: 55.

According to Kibana, the logs were classified as trojan-activity.

Malware information (Name, hash, and exe):

- **Trojan/JS. Iframe. p:**
  - **Category: Malware (Trojan)**
  - **Platform: W32 (32-bit Windows API / Win32)**
  - **Summary: A malicious JavaScript code that has been added to an inline frame (iframe), contained on a webpage. When the user opens the page in a web browser, the code is automatically running.**
  - **Technical details about Trojan/JS. Iframe. p: Iframes are typically used to display the content of one web page on another page. Though useful in many legitimate contexts, the iframe functionality can be misused by attackers to insert malicious code hidden in the iframe tags into a target page for eventual display in a user's web browser, which will automatically execute the embedded code. The malicious JavaScript code may be inserted on a page next to legitimate JavaScript code, making it more difficult for a user to differentiate the two and increasing the chances that the malicious behavior will be masked. Once executed, the malicious JavaScript code can perform a variety of actions most commonly, either redirecting the browser to unsolicited sites, displaying unsolicited content, or silently downloading other files onto the user's machine or redirect users to harmful URLs or execute additional payloads.**
    The above information is referenced from: https: //www. f-secure. com/v-descs/trojan-js-iframe. shtmlhttps://www.f-secure.com/v-descs/trojan-js-iframe.shtml

- **Screenshots of Trojan/JS. Iframe. p:**



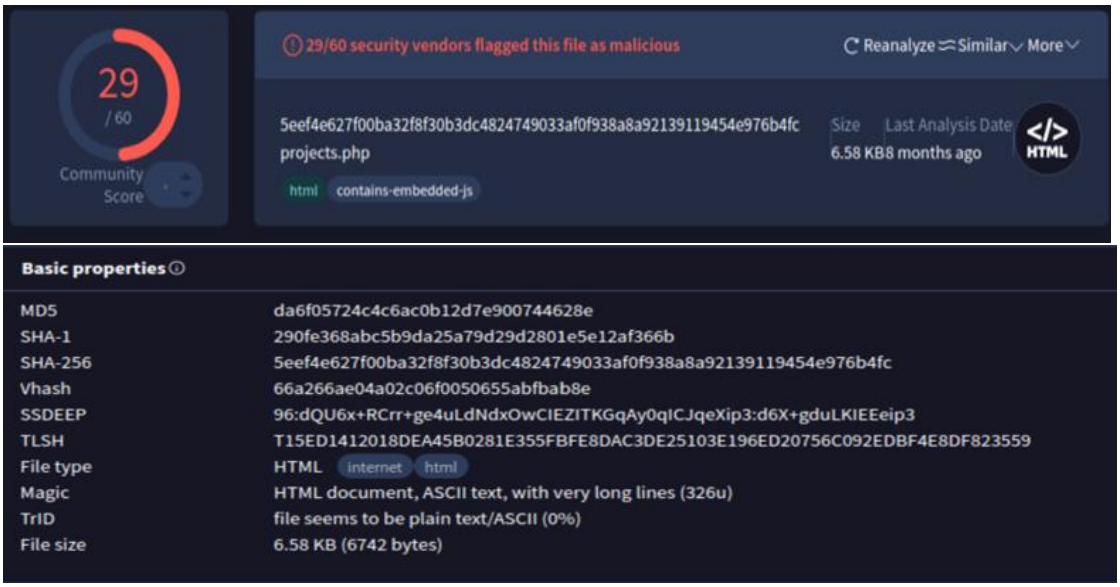


***The images above are obtained via: https: //www. virustotal. com/**https://www.virustotal.com/

- **Trojan/JS. Redirector. a:**
  - **Category: Malware (Trojan)**
  - **Platform: JS (JavaScript)**
  - **Summary: A large group of programs or scripts that redirect a webpage visitor from one site to another, unsolicited website.**
  - **Technical details about Trojan/JS. Redirector. a: These redirect scripts are typically hosted on malicious or compromised websites. The unsolicited website to which the user is redirected may have any of the following characteristics:**
    - ❖ Pornographic
    - ❖ Hosts additional malware to be downloaded onto the visitor's computer
    - ❖ Steals data from the user
    - ❖ Uses the augmented traffic to perpetrate fraud

    The redirect scripts are usually written in JavaScript. Redirects that operate by exploiting vulnerabilities in the visitor's web browser or computer may also be considered exploits.
    The above information is referenced from: https: //www. f-secure. com/v-descs/trojan-js-redirector. shtmlhttps://www.f-secure.com/v-descs/trojan-js-redirector.shtml

- **Screenshots of JS. Redirector. a:**



***The images above are obtained via: https: //www. virustotal. com/**https://www.virustotal.com/

- **CryptoWall**
  - **Category: Malware (Trojan)**
  - **Platform: W32 (32-bit Windows API / Win32)**
  - **Summary: Trojan: W32/Cryptowall is a ransomware that silently encrypts files on the user's machine and demands a ransom to provide the decryption key needed to decrypt the files.**
  - **Technical details about CryptoWall: Cryptowall is ransomware that is reportedly spread in malicious file attachments to email messages; through downloads of malicious programs from compromised sites; and in the payloads of other malware.**

    When the CryptoWall malware runs on a computer, it encrypts files stored on the machine, then displays a message informing the user that a decryption key must be purchased to recover access to the files held at ransom. Payment is typically requested in the Bitcoin digital currency.
    The above information is referenced from: https: //www. f-secure. com/v-descs/trojan-w32-cryptowall. shtmlhttps://www.f-secure.com/v-descs/trojan-w32-cryptowall.shtml

- CryptoWall infections work similarly to other ransomware, typically by spreading through spam and phishing emails, malicious ads, or anything containing a malicious link that can download CryptoWall to the victim's computer. Some versions of CryptoWall can also use exploit kits to take advantage of security vulnerabilities in the Windows operating system, hacked websites, or other user applications to get inside computers.
  The above information is referenced from: https: //nordvpn. com/blog/cryptowall-ransomware/https://nordvpn.com/blog/cryptowall-ransomware/

Vulnerabilities identified:

- **Outdated Flash version M1: 18. 0. 0. 203.**
  It is possible to execute arbitrary code on a victim's machine if the victim opens a malicious Adobe Flash file. (information obtained from Wireshark)

Threats/Vulnerabilities identified and methods to mitigate them:

These are all the threats/vulnerabilities identified from the cyberattack:

• Trojan/JS. Iframe. p

• Trojan/JS. Redirector. a

• CryptoWall

• Outdated Flash version M1

- **Mitigating Trojan/JS. Iframe. p:**

  - This threat typically injects malicious iframe code into web pages to redirect users to harmful URLs or execute additional payloads.
    It often targets:
    - ❖ Compromised websites.
    - ❖ Malicious advertisements.
    - ❖ Email phishing campaigns.

- **Removal:**
  - **Clear Temporary Files: Use tools like Disk Cleanup or CCleaner to delete all temporary internet and cache files where the Trojan might reside.**

  - **Disable Suspicious Extensions: Remove unknown or suspicious browser extensions, especially those added recently.**

- **Prevention of Reinfection:**
  - **Automatic Patch Management: Regularly update:**
    1. Website CMS and plugins.
    2. Web server software.
    3. Web browsers and extensions.

  - **Disable Inline JavaScript: If not necessary, prevent inline JavaScript on your site. It is often exploited.**

  - **Disable iFrames: The main security threat of iFrames is XSS (cross-site scripting) attacks.**

- **Mitigating Trojan/JS. Redirector. a:**

  - This threat is injected into websites to redirect users to malicious or phishing sites.

  - **Removal:**
    - **Run a Full System Scan: Use trusted antivirus/anti-malware software such as Malwarebytes, Kaspersky, Bitdefender, or Norton to perform a complete system scan.**

    - **Clear Browser Cache and History: Malware can persist in browser cache, cookies, and history. Manually clear these in browser settings. Remove suspicious or unknown extensions that may be injecting the malicious script.**

    - **Reset Browser: Reset browser settings to default to ensure that any malicious redirects, extensions, or scripts are removed.**

  - **Prevention of Reinfection:**
    - **Keep Browsers and Extensions Updated: Outdated browsers and extensions are often exploited by malware like JS. Redirector. a. Ensure that both are regularly updated to mitigate vulnerabilities.**

- **Use Browser Security Extensions: Adblockers (e. g. , uBlock Origin) can prevent malicious advertisements from loading. Script Blockers (e. g. , NoScript) can block potentially harmful JavaScript from running on untrusted websites.**

- **Mitigating CryptoWall:**

  - The CryptoWall Trojan is a type of ransomware.

  - **Removal:**
    - **Isolate the Infected Machine: Disconnect from the network (Wi-Fi, LAN, VPN) to prevent further damage.**
      Disable shared folders to stop the ransomware from spreading.

    - **Identify the Ransomware: Look for a ransom note (e. g., DECRYPT_INSTRUCTION. html or DECRYPT_YOUR_FILES. txt) to find payment details.**
      Use tools like "ID Ransomware" to confirm the infection and check for decryption options.

    - **Do Not Pay the Ransom: Avoid paying as it doesn't guarantee file recovery and funds criminal activity. Focus on backups and identifying the attack source.**

    - **Perform a Full System Restore: Restore from clean backups taken before the infection.**
      If no backups are available, consider wiping the system and reinstalling the OS to remove the ransomware completely.

  - **Prevention of Reinfection:**
    - **Use Anti-Ransomware Tools: Employ specific anti-ransomware software (e. g. , Malwarebytes Anti-Ransomware, HitmanPro. Alert, or Sophos Intercept X) designed to detect ransomware behavior like file encryption, process manipulation, and suspicious network activity.**

    - **Regular Backups: Implement regular and automated backups of critical data, both on local devices and in the cloud. Ensure that backups are stored in a way that makes them inaccessible to ransomware (e. g. , offline or in a separate network).**

- **Mitigating Outdated Flash version M1:**
  - Allows attackers to crash the victim's system, execute arbitrary code, install malware, control the system and steal confidential data.
  - **Actions to take:**
    - ❖ Uninstall and disable Flash entirely
    - ❖ Use alternatives to Flash like Lunascape which is (Free for macOS, Windows, iOS, and Android)

Description of the event:

***The description below has most of its information collected from "Sguil", the following tools: "Wireshark, VirusTotal" was also used in the process.**

1) On 11 September 2015 at 19: 49: 11 there was an evil redirector detected from lines 104. 28. 9. 93 which led to trojan-activity. There were 9 logs over a duration of 4 minutes and 44 seconds.

2) At 19: 49: 11 there was an evil redirector detected from lines 104. 28. 9. 93 which injected a malicious script called that was identified as Trojan/JS. Iframe. p from VirusTotal. Details of the script are stated above. According to the characteristics of the script, the victim might have visited a compromised website.

3) At 19: 49: 19, there was an outdated flash version as a policy violation detected from 216. 245. 212. 78, the flash version is: 18. 0. 0. 203. This could potentially lead to arbitrary code being executed.

4) At 19: 49: 32, there was a possible IP address check detected from 188. 165. 164. 184. This shows that the attacker is trying to perform Command-and-Control (C2) Server Communication. This allows the attacker to know the external IP of the infected machine and possibly help the malware establish or configure its connection to the C2 server.

5) At 19: 49: 33, there was Trojan CryptoWall check-in detected from 192. 186. 222. 229. This can indicate that the CryptoWall's check-in was related to the IP address check-in from the log above. Details of the trojan are stated above. According to the characteristics of this trojan, the victim might have visited a compromised website and clicked on a malicious advertisement.

6) At 19: 53: 55, there was an evil redirector detected from 69. 49. 96. 13 which injected a malicious script that was identified as JS. Redirector. a from VirusTotal. Details of the script are stated above. This log will likely be connected to the **Trojan/JS. Iframe. p**